

HealthSync — Remediation Report

Version: 1.0.0 **Date:** 19 July 2026 **Author:** Oyekunle Oyekola **Classification:** Internal — Security & Development Teams

1. Summary

This report documents all vulnerabilities identified during the VAPT assessment and their remediation status. All Critical, High, and Medium findings have been remediated with code changes. Low and Informational findings have been assessed and either remediated or accepted with documented justification.

Category	Before	After
Critical vulnerabilities	2	0
High vulnerabilities	4	0
Medium vulnerabilities	3	0
Low vulnerabilities	3	0
Informational (accepted)	4	2
Overall Risk Rating	MEDIUM	LOW

2. Files Changed

File	Change Type	Purpose
src/lib/rate-limit.ts	NEW	Login brute-force protection (5 attempts / 15min, 30min lockout)
src/middleware.ts	NEW	Security headers (CSP, X-Frame-Options, HSTS, Referrer-Policy, Permissions-Policy)
src/lib/sanitize.ts	NEW	Input sanitization for text fields (strips HTML, javascript: URIs, event handlers)
src/app/login/actions.ts	MODIFIED	Integrated rate limiting, audit logging of rate limit events
src/lib/auth.ts	MODIFIED	JWT secret validation (min 32 chars, rejects "dev-secret" in production)
src/app/(app)/patients/actions.ts	MODIFIED	Applied input sanitization to patient registration
next.config.ts	MODIFIED	Server action body size limit (1MB)

3. Remediation Details

3.1 CRITICAL — JWT Secret Validation (VULN-02)

File: `src/lib/auth.ts`

Before:

```
function secret() {  
  const value = process.env.JWT_SECRET;  
  if (!value) throw new Error("JWT_SECRET is not set");  
  return new TextEncoder().encode(value);  
}
```

After:

```
function secret() {  
  const value = process.env.JWT_SECRET;  
  if (!value) throw new Error("JWT_SECRET is not set");  
  if (  
    process.env.NODE_ENV === "production" &&  
    (value.length < 32 || value.includes("dev-secret"))  
  ) {  
    throw new Error(  
      "JWT_SECRET must be at least 32 characters and not contain 'dev-secret' in  
production",  
    );  
  }  
  return new TextEncoder().encode(value);  
}
```

Test: Application fails to start in production with weak secret. Succeeds with `openssl rand -base64 48` output.

3.2 HIGH — Login Rate Limiting (VULN-01)

File: `src/lib/rate-limit.ts` (new)

Implementation:

- In-memory Map keyed by client IP address
- 5 attempts allowed per 15-minute sliding window
- 30-minute lockout after exceeding limit
- Successful login resets the counter
- Periodic cleanup (every 5 minutes) prevents memory growth
- Rate limit events logged to audit trail as `auth.rate_limited` with IP

File: `src/app/login/actions.ts` (modified)

Integration:

- IP extracted from `x-forwarded-for` or `x-real-ip` headers
 - Rate limit checked before any database query or password verification
 - On lockout: returns human-readable message with remaining wait time
-

3.3 HIGH — Security Headers (VULN-03)

File: `src/middleware.ts` (new)

Headers applied to all routes:

Header	Value	Threat Mitigated
X-Content-Type-Options	<code>nosniff</code>	MIME-type confusion attacks
X-Frame-Options	<code>DENY</code>	Clickjacking
X-XSS-Protection	<code>1; mode=block</code>	Reflected XSS (legacy browsers)
Referrer-Policy	<code>strict-origin-when-cross-origin</code>	PHI leakage via Referer (VULN-09)
Permissions-Policy	<code>camera=(), microphone=(), geolocation=(), payment=()</code>	Unauthorized device access
Content-Security-Policy	<code>default-src 'self'; frame-ancestors 'none'; form-action 'self'</code>	XSS, clickjacking, form hijacking
Strict-Transport-Security	<code>max-age=31536000; includeSubDomains; preload</code>	Protocol downgrade (production only)

3.4 MEDIUM — Input Sanitization (VULN-04)

File: `src/lib/sanitize.ts` (new)

Functions:

- `sanitizeText(input)` — Strips `<>` characters, `javascript:` URIs, `on*=` event handlers
- `sanitizeFormData(raw, excludeFields)` — Applies `sanitizeText` to all fields except those in the `exclude` list

File: `src/app/(app)/patients/actions.ts` (modified)

Integration: `sanitizeFormData()` applied to all form data before Zod validation in `registerPatient()`.

Defense in depth: This is the second layer. React's JSX auto-escaping prevents rendering stored XSS in the current application. Sanitization protects downstream consumers (PDF exports, HL7 integrations, CSV reports) that may not have auto-escaping.

3.5 MEDIUM — Server Action Body Size Limit (VULN-05, VULN-16)

File: `next.config.ts` (modified)

Before:

```
const nextConfig: NextConfig = {};
```

After:

```
const nextConfig: NextConfig = {
  serverExternalPackages: ["bcryptjs"],
  experimental: {
    serverActions: {
      bodySizeLimit: "1mb",
    },
  },
};
```

4. Verification Matrix

Vulnerability	Remediation	Verification Method	Result
VULN-01 Brute force	Rate limiting	6 rapid failed logins	Blocked on 6th attempt
VULN-02 Weak JWT	Secret validation	Start with short secret in prod	Application refuses to start
VULN-03 Missing headers	Middleware	curl -sI response	All headers present
VULN-04 XSS	Input sanitization	Submit <script> in patient name	Tags stripped
VULN-05 Body size	Config limit	Next.js enforces 1MB limit	Large payloads rejected
VULN-09 Referrer leak	Referrer-Policy header	Cross-origin navigation	Only origin sent, not path
VULN-13 Dependencies	Current versions	npm audit	0 vulnerabilities

5. Regression Testing

All existing functionality verified after remediation:

- Build: `npm run build` — **0 TypeScript errors, all 15 routes compiled**
- Acceptance: `scripts/verify.ts` — **21/21 checks pass**
- Login flow: Admin login → dashboard → patients → encounter → ward — **functional**
- RBAC: Nurse denied prescribe, billing denied record:write — **enforced**
- CDS: Allergy alert + drug interaction alert — **firing correctly**
- Patient portal: Scoped queries, signed records only — **working**
- Security headers: Present on all responses — **verified via curl**

6. Deployment Checklist for Remediated Version

- ☐ Generate production JWT secret: `openssl rand -base64 48`

- ☐ Set `NODE_ENV=production` in service configuration
- ☐ Verify `npm run build` succeeds
- ☐ Run `scripts/verify.ts` against production database
- ☐ Verify security headers with `curl -sI https://healthsync.hospital.local/`
- ☐ Test login rate limiting (6 rapid failures should be blocked)
- ☐ Confirm HTTPS redirect from HTTP
- ☐ Change all default user passwords
- ☐ Run `npm audit` and confirm 0 vulnerabilities

End of Remediation Report